

Experimentos de Seguridad Criptografica

EAV · CPA · CCA · Mac-Forge · Sig-Forge

ITBA – Criptografía y Seguridad | June 25, 2026

Contents

1	Estructura General	1
2	PrivK^{eav} — Eavesdropping	2
2.1	Protocolo	2
2.2	Descripcion informal	2
3	PrivK^{CPA} — Chosen Plaintext Attack	3
3.1	Protocolo	3
3.2	Consecuencia fundamental	3
3.3	Ataque sobre esquema determinista	4
4	PrivK^{CCA} — Chosen Ciphertext Attack	4
4.1	Protocolo	4
4.2	Resultado clave	5
4.3	Ataque sobre cifrado de flujo	5
5	Mac-Forge — Infalsificabilidad de MAC	5
5.1	Protocolo	5
5.2	Metodo general para romper un MAC inseguro	6
5.3	Tres MACs rotos (patrones de examen)	6
6	Sig-Forge — Infalsificabilidad de Firma Digital	7
6.1	Protocolo	7
6.2	Dos diferencias respecto a Mac-Forge	7
6.3	Ataques sobre RSA-Firma textbook	7
7	Tabla Comparativa	8

1 Estructura General

Todos los experimentos siguen la misma estructura: el adversario $\mathcal{A}$ intenta distinguir cual de dos opciones elige el sistema. Lo que cambia entre experimentos es **cuanto poder extra** tiene $\mathcal{A}$.

Jerarquía de seguridad:

$$\underbrace{\text{EAV} \subseteq \text{Mult} \subseteq \text{CPA} \subseteq \text{CCA}}_{\text{confidencialidad}} \quad | \quad \underbrace{\text{Mac-Forge} \rightarrow \text{Sig-Forge}}_{\text{integridad}}$$

Cada flecha significa: “si eres seguro contra X , eres seguro contra todo lo anterior”. La jerarquía va de *menos poder del adversario* (EAV) a *mas poder* (CCA).

2 PrivK^{eav} — Eavesdropping**PrivK^{eav} — Escucha Pasiva**

Pregunta: ¿Puede $\mathcal{A}$, solo con *ver* un criptograma, deducir cual de dos mensajes fue cifrado?

2.1 Protocolo

Adversario $\mathcal{A}$	Challenger Π
Elige m_0, m_1 con $ m_0 = m_1 $	Genera $k \leftarrow \mathcal{K},$ $b \leftarrow \{0, 1\}$
$\xrightarrow{m_0, m_1}$	Calcula $c = \text{Enc}_k(m_b)$
$\xleftarrow{c}$	
Emite $b' \in \{0, 1\}$	

$\mathcal{A}$ gana si $b' = b$. El esquema es EAV-seguro si:

$$\Pr[\text{PrivK}_{\mathcal{A}, \Pi}^{\text{eav}}(n) = 1] \leq \frac{1}{2} + \text{negl}(n)$$

2.2 Descripción informal

$\mathcal{A}$ recibe **UN** criptograma y nada mas. El sistema es seguro si $\mathcal{A}$ no puede hacer mejor que tirar una moneda. Puede realizar cualquier computación, ser tan inteligente como quiera — simplemente no puede pedirle al sistema que cifre mensajes adicionales.

“El soplón con la oreja en la puerta” — $\mathcal{A}$ intercepta una carta sellada que contiene uno de dos mensajes que el mismo eligió. Solo mirando el sobre, no puede saber cual mensaje esta adentro.

3 PrivK^{CPA} — Chosen Plaintext Attack

PrivK^{CPA} — Ataque de Texto Plano Elegido

Pregunta: Si $\mathcal{A}$ puede cifrar cualquier mensaje que quiera, ¿puede adivinar cual de sus dos mensajes cifro el sistema?

3.1 Protocolo

Adversario $\mathcal{A}$	Challenger Π
	Genera $k \leftarrow \mathcal{K}$
Consultas al oraculo $\text{Enc}_k(\cdot)$ (ilimitadas)	
Elige m_0, m_1 con $ m_0 = m_1 $	
$\xrightarrow{m_0, m_1}$	
	Elige $b \leftarrow \{0, 1\}$
$\xleftarrow{c}$	Calcula $c = \text{Enc}_k(m_b)$
Sigue usando el oraculo	
Emite $b' \in \{0, 1\}$	

$\mathcal{A}$ gana si $b' = b$. El esquema es CPA-seguro si:

$$\Pr[\text{PrivK}_{\mathcal{A}, \Pi}^{\text{cpa}}(n) = 1] \leq \frac{1}{2} + \text{negl}(n)$$

3.2 Consecuencia fundamental

CPA-Seguro $\Rightarrow$ el cifrado debe ser probabilístico.

Cualquier cifrado *determinista* falla CPA automaticamente: $\mathcal{A}$ consulta $\text{Enc}_k(m_0)$ y $\text{Enc}_k(m_1)$, compara con c , y gana con probabilidad 1.

3.3 Ataque sobre esquema determinista

1. Consultar el oraculo: $c_0 = \text{Enc}_k(m_0)$ y $c_1 = \text{Enc}_k(m_1)$.
2. Recibir desafío c .
3. Si $c = c_0 \Rightarrow b' = 0$; si $c = c_1 \Rightarrow b' = 1$.
4. Como el cifrado es determinista, $\Pr[\text{ganar}] = 1$.

“La fotocopidora de mensajes secretos” — $\mathcal{A}$ tiene acceso ilimitado a la maquina de cifrado enemiga. El sistema debe resistir aun asi. La unica salida: producir un criptograma diferente cada vez (cifrado probabilistico).

4 $\text{PrivK}^{\text{CCA}}$ — Chosen Ciphertext Attack

$\text{PrivK}^{\text{CCA}}$ — Ataque de Texto Cifrado Elegido

Pregunta: Si $\mathcal{A}$ puede cifrar y descifrar cualquier cosa (salvo el desafio exacto), ¿puede distinguir?

4.1 Protocolo

Adversario $\mathcal{A}$	Challenger Π
	Genera $k \leftarrow \mathcal{K}$
Oracles $\text{Enc}_k(\cdot)$ y $\text{Dec}_k(\cdot)$	
Elige m_0, m_1	
$\xrightarrow{m_0, m_1}$	
	Elige $b \leftarrow \{0, 1\}$
$\xleftarrow{c}$	Calcula $c = \text{Enc}_k(m_b)$
Sigue usando oracles (<i>excepto</i> $\text{Dec}_k(c)$)	
Emite $b' \in \{0, 1\}$	

$\mathcal{A}$ gana si $b' = b$. **Restriccion:** $\mathcal{A}$ no puede consultar $\text{Dec}_k(c)$ directamente.

4.2 Resultado clave

Ningun cifrado estandar por si solo es CCA-seguro. Se necesita **cifrado autenticado** (**cifrado + MAC**) para lograr CCA-seguridad. La *maleabilidad* de los cifrados sin autenticacion permite ataques creativos.

4.3 Ataque sobre cifrado de flujo

Sea $c = m_b \oplus k$ el desafio (cifrado de flujo):

1. Recibir desafio $c = m_b \oplus k$.
2. Construir $c' = c \oplus (m_0 \oplus m_1)$. Nota: $c' \neq c$, permitido.
3. Consultar $\text{Dec}_k(c') = m_b \oplus (m_0 \oplus m_1)$, que es m_1 si $b = 0$ o m_0 si $b = 1$.
4. Comparar con m_0, m_1 para determinar b . Exitio con $\text{Pr} = 1$.

“El agente doble con un limite” — $\mathcal{A}$ trabaja dentro de la organizacion enemiga, puede enviar y recibir mensajes cifrados. La unica regla: no puede pasar el mensaje interceptado directamente al descifrador. Debe ser creativo (modificarlo levemente). Sin MAC, esa creatividad es suficiente.

5 Mac-Forge — Infalsificabilidad de MAC

Mac-Forge — Infalsificabilidad de MAC

Pregunta: Con acceso ilimitado al oraculo de etiquetado, ¿puede $\mathcal{A}$ producir un par (mensaje, etiqueta) valido para un mensaje que nunca consulto?

5.1 Protocolo

Adversario $\mathcal{A}$	Challenger MAC
	Genera $k \leftarrow \mathcal{K}$
Consultas al oraculo $\text{Mac}_k(\cdot)$ Sea Q el conjunto de mensajes consultados Emite (m, t) con $m \notin Q$	$\Rightarrow$

$\mathcal{A}$ gana si $\text{Vrfy}_k(m, t) = 1$ y $m \notin Q$.

Diferencia clave con PrivK: No hay bit b que adivinar. El objetivo es *falsificar*: producir una etiqueta valida para algo que nunca se consulto. La restriccion $m \notin Q$ evita el ataque trivial.

5.2 Metodo general para romper un MAC inseguro

Paso 1. Encontrar debilidad estructural: ¿Procesa el mensaje completo? ¿Es determinista? ¿Expone material de clave?

Paso 2. Consulta estrategica: pedir etiqueta del mensaje “especial” (ceros, prefijo) para extraer informacion.

Paso 3. Construir falsificacion: usar info extraida para construir (m, t) con $m \notin Q$.

Paso 4. Verificar: comprobar que $\text{Vrfy}_k(m, t) = 1$.

5.3 Tres MACs rotos (patrones de examen)

1. Consultar $f(0 \cdots 0)$ para obtener $G(k) \oplus 0 \cdots 0 = G(k)$.
2. Emitir $(1 \cdots 1, G(k) \oplus 1 \cdots 1)$.
3. Verificacion: $G(k) \oplus (1 \cdots 1) = G(k) \oplus 1 \cdots 1$. ✓

1. Consultar $f(0 \cdots 0)$ para obtener $k \oplus 0 \cdots 0 = k$.
2. Ahora se puede etiquetar cualquier mensaje. Emitir $(m^*, k \oplus \text{first}_\ell(m^*))$ con $m^* \notin Q$.
3. Alternativa: tomar cualquier m , agregar bits al final (no verificados por el MAC).

1. El MAC solo verifica la *longitud* del mensaje.
2. Consultar $f(\text{"ab"})$ para obtener $t = \text{Enc}_k(2)$.
3. Emitir $(\text{"xy"}, t)$. Como $|\text{"xy"}| = |\text{"ab"}| = 2$, la verificacion pasa. ✓

“El falsificador de documentos notariales” — $\mathcal{A}$ tiene un notario que firma cualquier cosa. Condicion de victoria: presentar un documento firmado que el notario nunca vio. Si el MAC tiene alguna regularidad (usa solo parte del mensaje, expone clave, es aditivo), $\mathcal{A}$ lo explota.

6 Sig-Forge — Infalsificabilidad de Firma Digital

Sig-Forge — Infalsificabilidad de Firma Digital

Pregunta: Con pk y acceso al oráculo de firma, ¿puede $\mathcal{A}$ generar una firma válida para un mensaje que nunca firmó?

6.1 Protocolo

Adversario $\mathcal{A}$	Challenger Sig
	Genera $(sk, pk) \leftarrow$ Gen
Recibe pk $\xleftarrow{pk}$	
Consultas al oráculo $\text{Sign}_{sk}(\cdot)$ $\Rightarrow$	
Sea Q el conjunto de mensajes consultados	
Emite (m, σ) con $m \notin Q$	

$\mathcal{A}$ gana si $\text{Vrfy}_{pk}(m, \sigma) = 1$ y $m \notin Q$.

6.2 Dos diferencias respecto a Mac-Forge

1. $\mathcal{A}$ también tiene pk — puede *verificar sus propios intentos* sin consultar al oráculo.
2. La verificación usa clave pública — cualquiera puede verificar, lo que otorga **no repudio**.

6.3 Ataques sobre RSA-Firma textbook

1. Elegir σ al azar.
2. Calcular $m = \sigma^e \bmod n$. Por definición de RSA, $\sigma = m^d \bmod n$.
3. El par (m, σ) es una firma válida *sin ninguna consulta al oráculo*.

Dado $s_1 = \text{Sign}_{sk}(m_1) = m_1^d \bmod n$ y $s_2 = \text{Sign}_{sk}(m_2) = m_2^d \bmod n$:

1. Calcular $s = s_1 \cdot s_2 \bmod n = (m_1 \cdot m_2)^d \bmod n$.
2. El par $(m_1 \cdot m_2 \bmod n, s)$ es una firma válida.
3. Si $m_1 \cdot m_2 \bmod n \notin Q$, es una falsificación exitosa.

Solucion: Firmar $H(m)$ en lugar de m (RSA con hash).

“Falsificar la firma de un funcionario” — $\mathcal{A}$ tiene pk (puede verificar) y puede pedirle al funcionario que firme cualquier cosa. Victoria: presentar un documento firmado que el funcionario nunca vio. Ventaja sobre MAC: se pueden verificar propios intentos con pk sin preguntar a nadie.

7 Tabla Comparativa

	EAV	CPA	CCA	Mac-Forge	Sig-Forge
Objetivo	Distinguir m_0/m_1	Distinguir m_0/m_1	Distinguir m_0/m_1	Falsificar etiqueta	Falsificar firma
Oracles disponibles	Ninguno	Enc($\cdot$)	Enc($\cdot$), Dec($\cdot$)	Mac($\cdot$)	Sign($\cdot$)
Restriccion	—	—	Dec(c) prohibido	pro- $m \notin Q$	$m \notin Q$
Clave publica	No	No	No	No	Si (pk)
Necesita prob.	No (pero ayuda)	Si (obligatorio)	Si	No aplica	No aplica
Construccion segura	OTP, PRG	PRF/PRP modo CTR	Cifrado autenticado	PRF con dominio extendido	RSA + Hash
Propiedad garantizada	Confidencialidad basica	Confidencialidad CPA	Confidencialidad + integridad	Autenticidad	Autenticidad + no repudio

Regla de oro: Si necesitas confidencialidad y autenticidad, usa **cifrado autenticado** (CCA-seguro). Nunca confundas confidencialidad con autenticidad: un mensaje cifrado sin MAC puede ser alterado sin saberlo.